

ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
«САНКТ-ПЕТЕРБУРГСКИЙ НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ
УНИВЕРСИТЕТ ИНФОРМАЦИОННЫХ ТЕХНОЛОГИЙ,
МЕХАНИКИ И ОПТИКИ»

Факультет безопасности информационных технологий

Дисциплина:

«Теория информационной безопасности и методология защиты информации»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ № 4
«Деловая игра по ИБ»

Выполнили:

Студент гр. N3248

Жук Анастасия Валерьевна

(подпись)

Студент гр. N3248

Пресняков Дмитрий Станиславович

(подпись)

Студент гр. N3248

Зуева Анастасия Владимировна

(подпись)

Проверил:

Кондратенко Станислав Сергеевич

(подпись)

(отметка о выполнении)

Санкт-Петербург
2024г.

Описание ситуации:

Ваша компания – крупная корпорация, специализирующаяся на разработке программного обеспечения.

Утро понедельника. Сотрудники компании получили массовую рассылку электронной почты с заголовком «Срочно! Новый регламент работы с документами». Письмо выглядит вполне официально, на первый взгляд не вызывает подозрений. Отправитель – «IT-отдел компании», но внимательные сотрудники могли бы заметить, что домен отправителя чуть отличается от корпоративного: вместо it-department@company.com указан it-department@compony.com!

Письмо:

Уважаемые коллеги!

Во вложении вы найдете обновленный регламент работы с документами.

Ознакомьтесь с ним до конца рабочего дня, чтобы избежать недоразумений.

С уважением,

IT-отдел компании.

К письму прикреплен файл с именем «Регламент_документы_2024.pdf.exe», иконка файла замаскирована под PDF-документ.

Несколько сотрудников, не задумываясь, открывают вложение. Как только файл запускается, система начинает работать нестабильно. Через несколько минут на экранах компьютеров появляется сообщение:

«Ваши файлы зашифрованы!»

Вы стали жертвой шифровальщика. Для восстановления данных переведите \$300 биткоинах на адрес 1A1zP1eP5QGefi2DMPTfTL5SLmv7DivfNa . У вас есть 72 часа. После этого ключ шифрования будет уничтожен навсегда.»

Игрокам предстоит принять ряд решений на каждом этапе, чтобы остановить угрозу, понять, с каким вирусом они столкнулись, и восстановить систему, избегая как финансовых, так и репутационных потерь.

Роли:

- **Сотрудник (обычный пользователь):** плохо разбирается в ИБ, склонен к панике;
- **Системный администратор:** хорошо знает системы компании, но недостаточно осведомлен о кибератаках;
- **Специалист по информационной безопасности:** знает об атаках и методах их устранения, но плохо разбирается в шифровании;
- **Криптограф (друг специалиста ИБ):** специалист, знающий все тонкости шифрования, но не всегда доступен для немедленной помощи.

1 Этап

Сотрудники открыли вложение из письма, и их компьютеры перестали работать. Появилось сообщение с требованием выкупа.

Сотрудники компании должны решить, как реагировать на сложившуюся ситуацию.

Варианты решений:

- Немедленно уведомить специалиста по ИБ (+ 10 баллов);
- Сообщить системному администратору (+7 баллов);
- Попытаться решить проблему самостоятельно, например заплатить выкуп или «потыкать на разные кнопки» (0 баллов).

2 этап (Если сотрудники позвали специалиста по ИБ)

Сотрудники сообщили специалисту по ИБ о случившемся. Он пошел посмотреть, и понял, что файлы зашифрованы...

Варианты решений:

- Найти специалиста по шифрованию по объявлению в интернете (+10 баллов);
- Обратиться к другу-криптографу за помощью (+7 баллов);
- Попытаться самостоятельно расшифровать данные (+1 балл).

2 Этап (Если сотрудники сообщили системному администратору)

Сотрудники сообщили сисадмину ситуацию. Он, не зная, как поступить, принимает одно из следующих решений:

Варианты решений:

- Позвать специалиста по ИБ (+10 баллов);
- Попробовать перезагрузить систему (+5 баллов).
- Перевести деньги вымогателям (0 баллов).

Если специалист по ИБ был вызван:

Имеем к тому же специалиста по криптографии (позвали друга или придет хороший специалист).

Если специалист по ИБ не был вызван:

Перезагрузка системы не помогает. Во время очередной плановой проверки (которые происходят несколько раз в день), специалист по ИБ обнаруживает аномалию на одном из компьютеров и идет изучать проблему. В итоге он также привлекает друга-криптографа для ускорения решения.

То есть, к 3 этапу у нас уже есть специалист по ИБ и криптограф.

3 Этап

Мы обратились к специалисту по криптографии, который провел обследование компьютера. Он сообщил, что, вероятно, расшифровать данные не удастся. Специалист отметил, что недавно сталкивался с похожим случаем, где причиной оказался вирус NotPetya. В текущей ситуации он предложил два возможных пути действий:

- ✓ Попробовать выполнить расшифровку, что займет около двух часов, после чего потребуется дополнительное время для проверки гипотезы.
- ✓ Проверить свою гипотезу сразу, что потребует около одного часа.

Решение зависит от приоритетов и срочности.

Варианты решений:

- Сразу проверить гипотезу, не занимаясь расшифровкой (+10 баллов);
- Попытаться расшифровать данные, после чего гипотеза будет проверяться (+7 баллов);
- Заплатить деньги мошенникам (0 баллов).

4 Этап

Вирус через уязвимость в локальной сети заражает другие компьютеры. Криптограф подтверждает, что это NotPetya. Для устранения вируса необходимо удалить все данные с зараженных компьютеров.

Варианты решений:

- Узнать у руководства компании про наличие резервных копий и получить разрешение на устранение вируса (+10 баллов);
- Самостоятельно спросить у сотрудников о наличии копий и принять решение об удалении (+5 баллов);
- Удалить данные, не удостоверившись в наличии резервных копий (0 баллов).

5 Этап

Убедившись в наличии резервных копий, можно приступить к ликвидации вируса. Некоторые важные файлы оказались повреждены, однако компания располагает резервными копиями данных. Включена резервная система управления процессами, которая позволяет временно поддерживать работу компании. Однако длительное использование этой системы может привести к финансовым потерям, поскольку обслуживание клиентов ограничено: текущие услуги предоставляются, но привлечение новых клиентов и развитие сервисов приостановлено. Специалист по криптографии подтвердил, что причиной инцидента является вирус NotPetya.

Варианты решений:

- Переустановить операционные системы на всех зараженных компьютерах, загрузить резервные копии и обучить сотрудников основам ИБ (+10 баллов);
- Купить новые компьютеры, установить на них резервные учетные записи и обучить сотрудников основам ИБ (+5 баллов);
- Уволить сотрудников, чтобы исключить риск повторения нежелательных ситуаций, нанять новых специалистов с уже необходимыми навыками и опытом и переехать в новый офис, считая старый «проклятым» (0 баллов).

В качестве референса для данной ситуации была взята компания «Роснефть», которая в 2017 году столкнулась с вирусом-шифровальщиком NotPetya. Атака парализовала часть IT-инфраструктуры компании, что привело к временной остановке рабочих процессов.

Благодаря тому, что компания перешла на резервную систему управления производственными процессами, ни добыча, ни подготовка нефти не были остановлены. Компания справилась с атакой за счет изоляции зараженных систем, использования резервных копий для восстановления данных и оперативного реагирования специалистов. После инцидента были устранены уязвимости, усилена защита и проведено обучение сотрудников.